

RISK ASSESSMENT OVERVIEW

TOTAL RISKS IDENTIFIED	● CRITICAL	● HIGH	● MEDIUM	● LOW
15	1	6	8	0

RISK DISTRIBUTION BY CATEGORY

Risk Category	Risk Count	Avg Score	Highest Score	Risk Level
Access Control	2	14	16	● HIGH
Access Management	1	12	12	● HIGH
Business Continuity	1	10	10	● MEDIUM
Compliance / Training	1	9	9	● MEDIUM
Cybersecurity	1	20	20	● CRITICAL
Data Protection	1	8	8	● MEDIUM
HIPAA Compliance	1	9	9	● MEDIUM
Incident Response	1	10	10	● MEDIUM
Insider Threat	1	16	16	● HIGH
Malware / Ransomware	1	15	15	● HIGH
Medical Device Security	1	12	12	● HIGH
Physical Security	1	8	8	● MEDIUM
Vendor Risk	1	6	6	● MEDIUM
Vendor Risk / HIPAA	1	10	10	● MEDIUM

TOP PRIORITY RISKS — IMMEDIATE ACTION REQUIRED

Risk ID	Description	Score	Treatment Action Required
WPH-R01	Staff fall for phishing email giving attacker unauthorized access to Epic EHR system	20	IT Security Manager
WPH-R02	Employee shares login credentials with colleague, enabling unauthorized patient record access	16	Privacy Officer
WPH-R04	Hospital employee accesses patient records without clinical justification — insider threat	16	Privacy Officer
WPH-R03	Ransomware attack encrypts all hospital systems causing complete clinical operations shutdown	15	IT Manager
WPH-R05	Unpatched vulnerability in medical device connected to hospital network exploited by attacker	12	IT Manager / Biomedical Engineering

KEY RECOMMENDATIONS TO EXECUTIVE LEADERSHIP

1	IMMEDIATE — 30 Days	Implement mandatory phishing simulation training and deploy MFA on all Epic EHR accounts. Conduct emergency vendor contract audit to identify all missing BAAs.
2	SHORT TERM — 60 Days	Establish formal incident response plan with defined roles. Conduct user access review to deactivate all former employee accounts. Enforce password complexity on all systems.
3	MEDIUM TERM — 90 Days	Implement offsite cloud backup with tested recovery procedures. Complete HIPAA audit log review process. Achieve 100% staff completion of HIPAA security awareness training.
4	ONGOING — Quarterly	Maintain and update this risk register. Conduct quarterly risk reviews with department heads. Monitor vendor compliance and renew BAAs annually.